Statement of Applicability

ISO/IEC 27001:2022, Clause 6.1.3 d)

Organization	Acme Financial Services (demo)	**Document ID**	SoA-MN-ISMS-2026-DEMO
ISMS scope	The ISMS covers the design, operation and support of the card payment processing platform, including the supporting IT infrastructure, data centers, and the people and processes that deliver these services from the head...	**Version**	1.0
Prepared by	Marsellino Nasry	**Approved by**	Chief Risk Officer
Date	12 Oct 2026	**Classification**	Confidential

Applicable: 92 of 93 | Excluded: 1 | Implemented: 61 | In progress: 20 | Not implemented: 11

Justification codes: LR legal or regulatory requirement; CO contractual obligation; BR business requirement or best practice; RA risk assessment result.

ID	Control	Applicable	LR	CO	BR	RA	Status	Justification and implementation reference	Risks
A.5 Organizational controls									
A.5.1	Policies for information security	Yes			X		Implemented	Information Security Policy v4.2 approved by the board; topic-specific policies reviewed within 12 months.	-
A.5.2	Information security roles and responsibilities	Yes			X		Not Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.3	Segregation of duties	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.4	Management responsibilities	Yes			X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.5	Contact with authorities	Yes	X		X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.6	Contact with special interest groups	Yes			X		Not Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.7	Threat intelligence	Yes			X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-

MARSELLINO NASRY

ID	Control	Applicable	LR	CO	BR	RA	Status	Justification and implementation reference	Risks
A.5.8	Information security in project management	Yes			X		Not Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.9	Inventory of information and other associated assets	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.10	Acceptable use of information and other associated assets	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.11	Return of assets	Yes			X		Not Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.12	Classification of information	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.13	Labelling of information	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.14	Information transfer	Yes			X	X	Not Implemented	Selected to treat R-002.	R-002
A.5.15	Access control	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.16	Identity management	Yes			X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.17	Authentication information	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.18	Access rights	Yes			X		In Progress	Quarterly access reviews completed for core banking. Q2 review for the payment switch was not evidenced.	-
A.5.19	Information security in supplier relationships	Yes		X	X	X	Implemented	Selected to treat R-003.	R-003
A.5.20	Addressing information security within supplier agreements	Yes		X	X	X	Implemented	Selected to treat R-003.	R-003
A.5.21	Managing information security in the ICT supply chain	Yes		X	X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-

MARSELLINO NASRY

ID	Control	Applicable	LR	CO	BR	RA	Status	Justification and implementation reference	Risks
A.5.22	Monitoring, review and change management of supplier services	Yes		X	X	X	Implemented	Selected to treat R-003.	R-003
A.5.23	Information security for use of cloud services	Yes		X	X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.24	Information security incident management planning and preparation	Yes			X	X	Implemented	Selected to treat R-001.	R-001
A.5.25	Assessment and decision on information security events	Yes			X		Not Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.26	Response to information security incidents	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.27	Learning from information security incidents	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.28	Collection of evidence	Yes			X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.29	Information security during disruption	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.30	ICT readiness for business continuity	Yes			X	X	In Progress	Selected to treat R-006.	R-006
A.5.31	Identification of legal, statutory, regulatory and contractual requirements	Yes	X		X	X	Implemented	Selected to treat R-008.	R-008
A.5.32	Intellectual property rights	Yes	X		X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.33	Protection of records	Yes	X		X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.34	Privacy and protection of personally identifiable information (PII)	Yes	X		X	X	In Progress	Selected to treat R-008.	R-008
A.5.35	Independent review of information security	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-

MARSELLINO NASRY

ID	Control	Applicable	LR	CO	BR	RA	Status	Justification and implementation reference	Risks
A.5.36	Compliance with policies, rules and standards for information security	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.5.37	Documented operating procedures	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.6 People controls									
A.6.1	Screening	Yes	X		X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.6.2	Terms and conditions of employment	Yes	X		X		Not Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.6.3	Information security awareness, education and training	Yes			X	X	Implemented	Selected to treat R-005.	R-005
A.6.4	Disciplinary process	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.6.5	Responsibilities after termination or change of employment	Yes			X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.6.6	Confidentiality or non-disclosure agreements	Yes		X	X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.6.7	Remote working	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.6.8	Information security event reporting	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7 Physical controls									
A.7.1	Physical security perimeters	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.2	Physical entry	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.3	Securing offices, rooms and facilities	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-

MARSELLINO NASRY

ID	Control	Applicable	LR	CO	BR	RA	Status	Justification and implementation reference	Risks
A.7.4	Physical security monitoring	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.5	Protecting against physical and environmental threats	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.6	Working in secure areas	Yes			X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.7	Clear desk and clear screen	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.8	Equipment siting and protection	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.9	Security of assets off-premises	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.10	Storage media	Yes			X	X	Implemented	Selected to treat R-002.	R-002
A.7.11	Supporting utilities	Yes			X	X	Implemented	Selected to treat R-006.	R-006
A.7.12	Cabling security	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.13	Equipment maintenance	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.7.14	Secure disposal or re-use of equipment	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8 Technological controls									
A.8.1	User endpoint devices	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.2	Privileged access rights	Yes			X	X	In Progress	Selected to treat R-004.	R-004
A.8.3	Information access restriction	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.4	Access to source code	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-

MARSELLINO NASRY

ID	Control	Applicable	LR	CO	BR	RA	Status	Justification and implementation reference	Risks
A.8.5	Secure authentication	Yes			X	X	Implemented	Selected to treat R-004, R-005.	R-004, R-005
A.8.6	Capacity management	Yes			X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.7	Protection against malware	Yes			X	X	Implemented	Selected to treat R-001.	R-001
A.8.8	Management of technical vulnerabilities	Yes			X	X	Implemented	Selected to treat R-001. Monthly authenticated scans are in place. In a sample of 25 critical findings, 6 exceeded the 14-day remediation SLA without an approved exception.	R-001
A.8.9	Configuration management	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.10	Information deletion	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.11	Data masking	Yes			X	X	Not Implemented	Selected to treat R-007.	R-007
A.8.12	Data leakage prevention	Yes			X	X	Not Implemented	Selected to treat R-002. No DLP capability for email, web or endpoints. Card data egress relies on firewall rules only.	R-002
A.8.13	Information backup	Yes		X	X	X	Implemented	Selected to treat R-001. Daily backups with weekly immutable copies. Restore test performed in Q2 met the 4-hour RTO.	R-001
A.8.14	Redundancy of information processing facilities	Yes		X	X	X	Implemented	Selected to treat R-006.	R-006
A.8.15	Logging	Yes	X		X	X	In Progress	Selected to treat R-004.	R-004
A.8.16	Monitoring activities	Yes			X	X	In Progress	Selected to treat R-004. SIEM operational; 18 of 64 critical servers are not yet forwarding logs.	R-004
A.8.17	Clock synchronization	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.18	Use of privileged utility programs	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.19	Installation of software on operational systems	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-

MARSELLINO NASRY

ID	Control	Applicable	LR	CO	BR	RA	Status	Justification and implementation reference	Risks
A.8.20	Networks security	Yes			X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.21	Security of network services	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.22	Segregation of networks	Yes			X		In Progress	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.23	Web filtering	Yes			X	X	Not Implemented	Selected to treat R-005.	R-005
A.8.24	Use of cryptography	Yes	X		X	X	In Progress	Selected to treat R-002.	R-002
A.8.25	Secure development life cycle	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.26	Application security requirements	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.27	Secure system architecture and engineering principles	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.28	Secure coding	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.29	Security testing in development and acceptance	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.30	Outsourced development	No					N/A	All software development is performed in-house; no development activity is outsourced within the ISMS scope.	-
A.8.31	Separation of development, testing and production environments	Yes			X	X	Implemented	Selected to treat R-007.	R-007
A.8.32	Change management	Yes			X		Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-
A.8.33	Test information	Yes			X	X	In Progress	Selected to treat R-007.	R-007
A.8.34	Protection of information systems during audit testing	Yes			X		Not Implemented	Selected as part of the ISMS risk treatment and baseline security requirements.	-

MARSELLINO NASRY

PREPARED BY

Marsellino Nasry

Signature and date

APPROVED BY

Chief Risk Officer

Signature and date

MARSELLINO NASRY